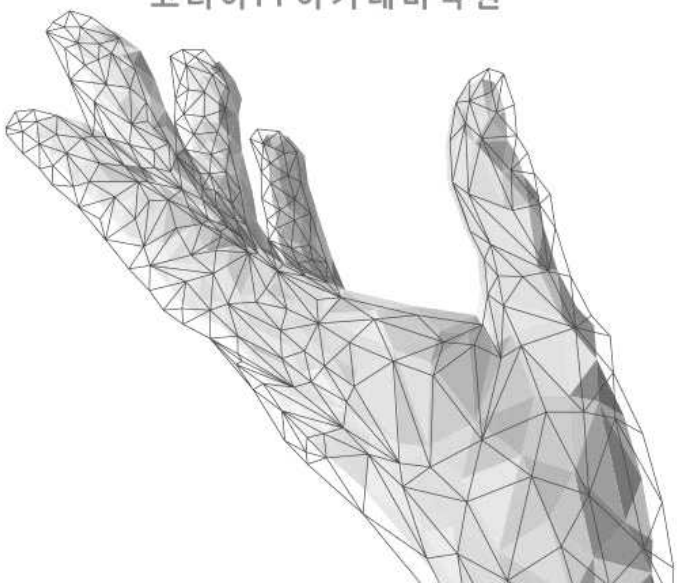
# NW 보안 구축

KOREA
코리아IT아카데미학원



| class | 정보보안 산업기사 취득과정 A |
|---|---|
| name | 조채언 |

# 목 차

□ 네트워크 보안 설계하기 ····· 3

1. 정보통신망법과 개인정보보호법의 관계 ····· 3

2. 네트워크 보안 관련 법적 요구사항 및 미준수 시 법적 책임 ····· 3

3. 망분리의 개념과 필요성 및 법적 기준 ····· 4

Ⅰ. 보안 침해 공격 방법 정의 및 시스템 영향 ····· 5

Ⅱ. 악성 프로그램 개념 정의 및 시스템 영향 ····· 6

Ⅲ. 침해 공격 방법 개념 정의 및 시스템 영향 ····· 7

Ⅳ. 네트워크 인프라 구성도 ····· 8

1. (pfsense)침입 탐지시스템(IPS/IDS) 구축 및 탐지 ····· 8

2. DHCP서버 및 NAT/Bridge 설정 ····· 11

3. 내부 네트워크 구축 ····· 13

Ⅴ. DoS(ICMP) 공격 차단 설정 ····· 15

# □ 네트워크 보안 설계하기

## 1. 정보통신망법과 개인정보보호법의 관계

| 구분 | 정보통신망법 | 개인정보보호법 |
|---|---|---|
| 성격 | 특별법 | 일반법 |
| 적용대상 | 정보통신망을 이용하는 사업자 | 모든 개인정보 처리자 (산업 구분 없음) |
| 주요 내용 | 개인정보 보호 및 정보보호 조치 규정 | 전반적인 개인정보 보호 기준 제공 |
| 세부 규정 | 개인정보 수집, 이용, 제공, 파기에 대한 명확한 기준 설정 | 정보통신망법이 적용되지 않은 영역 |
| 위반 시 | 벌칙 부과 | 법에 따른 제재 적용 |
| 적용 범위 | 정보통신망 관련 분야 한정 | 모든 분야 포괄적 적용 |
| 법 적용 관계 | 특별법으로 우선 적용 | 정보통신망법이 없는 부분 보완 |

## 2. 네트워크 보안 관련 법적 요구사항 및 미준수 시 법적 책임

### 가. 네트워크 보안을 강화하기 위한 법률적 요구사항

| | |
|---|---|
| 정보통신망법에 따른 보호 조치 | - 정보통신망을 이용하는 사업자는 침입 차단 시스템(방화벽, IDS/IPS 등)과 데이터 암호화 조치를 적용해야 한다.<br>- 개인정보를 수집하는 웹사이트는 SSL/TLS 암호화를 적용하여 정보의 유출을 방지해야 한다.<br>- 악성코드 유포 방지를 위해 보안 업데이트 및 백신 프로그램을 주기적으로 적용해야 한다. |
| 개인정보보호법의 안전조치 의무 | - 개인정보처리자는 내부 관리 계획 수립, 접근 통제, 접속 기록 보관 및 암호화를 통해 개인정보가 무단으로 유출되지 않도록 조치해야 한다.<br>- 원격 접속이 필요한 경우 VPN과 다중 인증을 적용해야 한다. |

나. 준수하지 않았을 경우 발생할 수 있는 법적 책임

| | |
|---|---|
| 과징금 및 행정 처분 | 정보통신망법 또는 개인정보보호법을 위반하면, 사업자는 벌금 또는 과징금을 부과받을 수 있다. |
| 형사처벌 | 중대한 개인정보 유출 사고가 발생할 경우, 사업자의 대표자나 보안책임자는 형사처벌을 받을 수 있다. |
| 손해배상 청구 | 개인정보가 유출되거나 서비스 장애가 발생하여 피해자가 발생하면, 사업자는 민사상 손해배상을 청구당할 수 있다. |

※ 기업과 기관은 법률적 요구사항을 준수하고, 주기적으로 보안 점검을 수행하여 법적 리스크를 최소화해야 한다.

## 3. 망분리의 개념과 필요성 및 법적 기준

| 구분 | 세부 항목 | 내용 |
|---|---|---|
| 개요 | 정의 | 내부 업무망과 외부 인터넷망을 물리적 또는 논리적으로 분리하여 외부 침입으로부터 중요 정보 시스템을 보호하는 기술적 조치 |
| | 적용 대상 | 금융권, 공공기관, 개인정보를 대량 처리하는 사업자 |
| 필요성 | 외부 해킹 방어 | 외부 해킹 공격으로부터 내부 업무망 보호 |
| | 정보 유출 방지 | 내부망에서 저장·처리되는 중요 정보<br>(개인정보, 기밀 문서, 금융 정보 등)의 외부 유출 차단 |
| | 피해 최소화 | 악성코드 감염 및 랜섬웨어 공격 확산 방지 및 피해 최소화 |
| 법적 기준 | 개인정보 보호법 제29조<br>(안전조치 의무) | 개인정보 처리자는 시스템 보호를 위한 기술적·관리적 조치 의무 |
| | 정보통신망법 시행령 제15조<br>(정보보호 조치) | 일정 규모 이상 사업자는 내부망·외부망 분리 및 정보 유출 방지 의무 |
| | ISMS-P 인증 기준 | 금융기관 및 공공기관은 망분리 필수, 미준수 시 인증 취득 어려움 |

※ 망분리는 단순한 보안 조치가 아니라 법적 요구사항이며, 이를 준수하지 않을 경우 법적 처벌 및 인증 취소 등의 불이익을 받을 수 있으므로 반드시 적용해야 한다.

# Ⅰ. 보안 침해 공격 방법 정의 및 시스템 영향

| 용어 | 의미 | 시스템 영향 |
|---|---|---|
| 디도스(DDoS) 공격 | 다수의 악성코드 감염 PC를 이용해 대규모 트래픽을 특정 시스템에 전송하여 네트워크 및 시스템의 과부하를 일으키고 정상 서비스를 방해하는 사이버 침해 공격 | 서버 과부하로 서비스 중단 |
| 스미싱 (Smishing) | 스마트폰 문자 발송 메시지를 통해 악성 앱 설치를 유도하고 개인정보 혹은 금융 정보를 탈취하는 침해 기법 | 개인정보 유출, 금전 피해 |
| 스피어 피싱 (Spear Phishing) | 창(Spear)과 피싱(Phishing)의 합성어로, 특정 공격 대상을 지정하고 다양한 방법을 통해 집중적으로 공격 대상을 공격하여 정보를 탈취하기 위한 수법 | 계정 탈취, 내부 시스템 침입 |
| 웹 해킹 (Web Hacking) | 웹서비스 요소를 공격하여 이용자 혹은 관리자의 권한을 획득하고 개인정보 등을 탈취하는 행위 | 데이터 유출, 권한 탈취 |
| APT (Advanced Persistent Threat, 지능형 지속 공격) | 특정 대상에 대해 명확한 목표를 설정하고 지능적이고 지속적으로 공격을 가하여 정보를 수집 및 유출하는 해킹 기법 | 장기적 정보 유출, 시스템 장악 |
| 포트 스캐닝 (Port Scanning) | 공격 대상 서버의 열려진 서비스 포트를 순차적으로 접속 시도함으로써, 취약한 포트를 찾아내는 공격 준비 기법 | 취약점 노출 → 추가 공격 위험 |
| 무작위 대입 공격 (Brute Force Attack) | Brute-force 공격이라고도 부르며, 사용자 인증이 필요한 기능에 비밀번호 등을 무작위로 대입하여 인증 성공을 노리는 공격 기법 | 계정 탈취 |
| 미라이봇넷 (Mirai Botnet) | IoT 기기를 통해, DDoS 공격을 하는 봇넷의 일종으로서 IoT 기기의 기본 계정을 통해 통제권을 획득하거나 다량의 트래픽을 유발하는 공격 방법 | 대규모 트래픽 유발, 서비스 마비 |

## Ⅱ. 악성 프로그램 개념 정의 및 시스템 영향

| 용어 | 의미 | 시스템 영향 |
|---|---|---|
| 랜섬웨어<br>(Ransomware) | 사용자 컴퓨터나 서버 시스템에 동의 없이 설치되어 파일을 암호화하고, 복호화를 원하는 사용자에게 돈을 요구하는 사이버 범죄에 사용되는 악성 프로그램 | 파일 및 시스템을 암호화하여 정상적인 사용 불가,<br>금전요구로 서비스 중단 발생 |
| 루트킷<br>(Rootkit) | 해커에 의해 설치된 악성코드가 백신이나 사용자에게 감지되지 않도록 숨겨 주는 악성 프로그램 | 관리자의 권한을 탈취하고, 탐지를 회피하여 장기적 통제 가능 |
| C&C 서버<br>(Command and Control Server) | 해커에 의해 악성코드에 감염된 좀비 PC를 관리하고 DDoS와 같은 공격 명령을 내리는 관리 및 제어 목적의 서버 | 감염된 시스템을 원격에서 제어하여 추가 공격 수행, 정보 유출 및 봇넷 구성 |
| 컴퓨터 바이러스<br>(Computer Virus) | 정상적인 실행 파일과 결합하여 PC의 동작을 중지시키거나 파일을 변조 혹은 파괴하는 등 컴퓨터의 운영을 방해하는 악성 프로그램 | 파일 감염 및 손상, 시스템 성능 저하 및 데이터 파괴 |
| 백도어<br>(Backdoor) | 사용자 컴퓨터나 서버 시스템에 해커가 사용자 몰래 접속하여 악의적인 행위를 할 수 있도록 출입구 역할을 해 주는 악성 프로그램 | 인증 없이 시스템 접근 가능, 보안 우회 및 지속적인 침입 경로 제공 |
| 좀비 PC<br>(Zombie PC) | 해커가 원격에서 제어할 수 있는 악성 프로그램이 설치되어, 사용자 모르게 스팸 발송, 악성코드 유포, DDoS 등의 공격에 활용되는 컴퓨터 | 공격자에 의해 원격 제어되어 DDoS 공격 등<br>악의적인 행위에 이용됨 |
| 웜<br>(Worm) | 다른 파일을 변조하여 기생하지 않고 독자적으로 자신을 복제하여 확산함으로써 전파 속도가 매우 빠른 특징을 지니며 주로 메일, 네트워크 공유 폴더 등을 통해 전파되고 시스템과 네트워크에 부하를 증가시키는 악성 프로그램 | 네트워크를 통해 자동 확산, 시스템 과부하 및 네트워크 장애 유발 |
| 웹셸<br>(Web Shell) | 해커가 원격으로 웹서버 시스템에 악의적인 명령을 실행할 수 있도록 작성한 웹 브라우저 기반의 스크립트 실행 파일 | 웹 서버에 설치되어 원격 명령 실행 가능, 서버 장악 및 데이터 유출 |
| 익스플로잇<br>(Exploit) | 해커가 소프트웨어나 하드웨어의 취약점을 통해 악성 행위를 수행하기 위해 제작한 프로그램 | 취약점을 이용해 시스템 침입 및 권한 상승, 악성코드 실행 유도 |
| 제로데이 취약점<br>(Zero-day Vulnerability) | 보안 패치가 발표되지 않은 상태에서 외부에 노출된 취약점 | 패치되지 않은 취약점 악용으로 방어 어려움, 심각한 보안 침해 발생 |
| 키로거<br>(Keylogger) | 사용자의 키보드 입력 데이터를 해커에게 전송하는 악성 프로그램 | 사용자 입력 정보(비밀번호 등) 탈취, 개인정보 및 계정 유출 |
| 트로이 목마<br>(Trojan Horse) | 컴퓨터에 숨어 있으면서 사용자의 정보를 사용자가 인지하지 못하도록 유출하는 악성코드 | 정상 프로그램으로 위장하여 설치 후 정보 탈취 및 시스템 제어 |

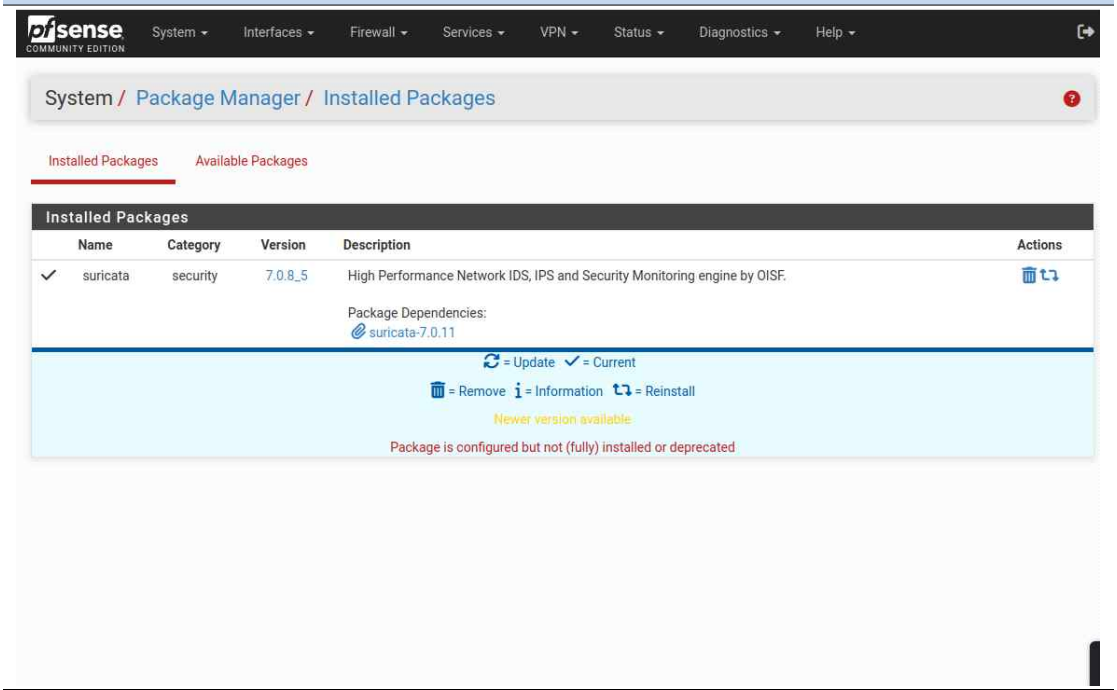
## Ⅲ. 침해 공격 방법 개념 정의 및 시스템 영향

| 용어 | 의미 | 시스템 영향 |
|---|---|---|
| SQL 인젝션<br>(SQL Injection) | SQL을 사용하는 응용프로그램에서 SQL 구문을 조작하여 인증 우회 혹은 권한 상승을 유발하는 공격 | 데이터베이스 정보 유출, 데이터 변조 및 삭제, 관리자 권한 탈취 |
| 크로스 사이트 스크립트<br>(XSS, Cross Site Scripting) | 웹사이트에 악성 스크립트를 삽입할 수 있는 취약점을 활용하여, 의도하지 않은 기능을 수행하거나 중요 정보를 탈취하는 공격 | 사용자 쿠키 및 세션 정보 탈취, 악성 코드 실행, 사용자 계정 도용 |
| 크로스 사이트 요청 위조<br>(CSRF, Cross Site Request Forgery) | 웹서버가 피해자의 정당한 웹 요청이라고 오해하게 만들도록 웹사이트에 피해자의 세션 쿠키 및 인증 정보를 자동으로 포함하여 위조된 웹 요청을 강제로 보내도록 하는 공격 | 사용자 권한으로 데이터 변경, 계정 설정 변경, 금전 거래 등 피해 발생 |
| 파일 업로드<br>(웹셸, Web Shell) | 허용되지 않은 유형의 파일을 업로드하고 해당 파일을 외부에서 직접 접근할 수 있는 취약점을 활용하여 웹서버의 권한을 탈취하는 공격 | 웹 서버 장악, 악성코드 실행, 웹셸 설치 및 데이터 유출 |
| 파일 다운로드<br>(File Download) | 검증되지 않은 외부 입력값을 이용하여 서버의 파일에 접근하고 식별 가능한 취약점을 이용하여 중요 서버 파일을 탈취하는 공격 | 중요 시스템 파일 및 개인정보 유출 |
| 세션 탈취<br>(Session Hijacking) | 크로스 사이트 스크립트 등의 방법을 이용하여 피해자의 세션 쿠키를 탈취하고 이를 이용해 피해자의 세션으로 로그인하는 공격 | 사용자 계정 도용, 인증 우회, 개인정보 및 서비스 오남용 |

# Ⅳ. 네트워크 인프라 구성도

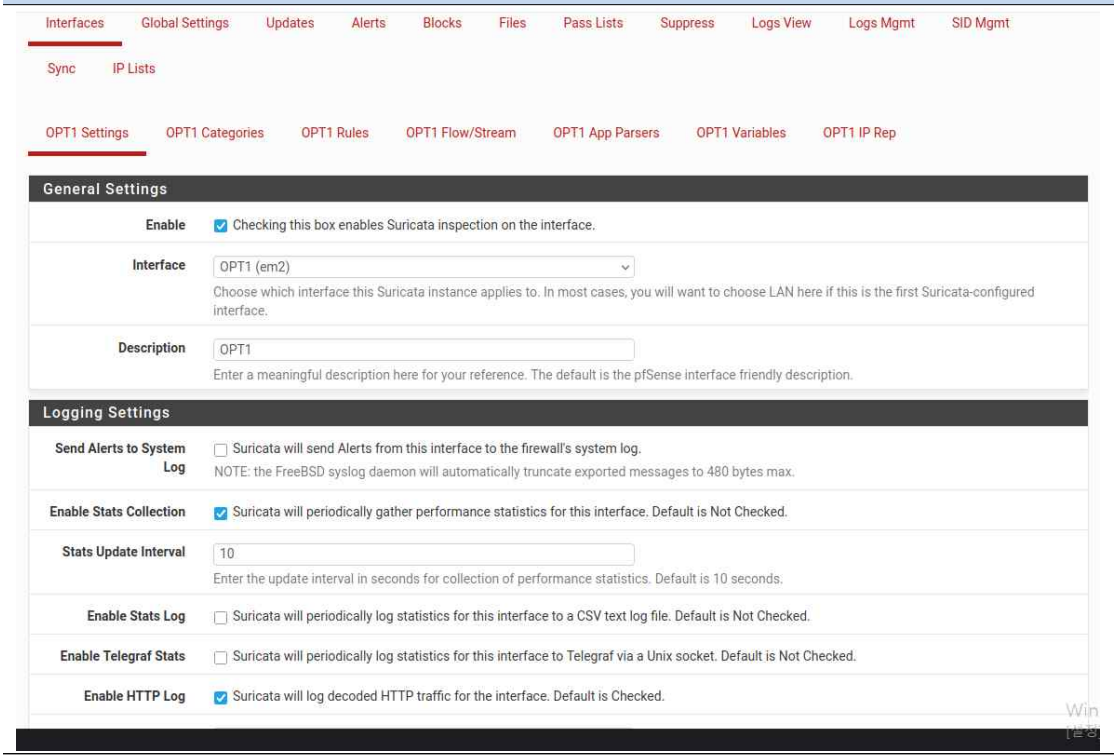
## □ (pfsense)침입 탐지시스템(IPS/IDS) 구축 및 탐지

### 1. Suricata 구축



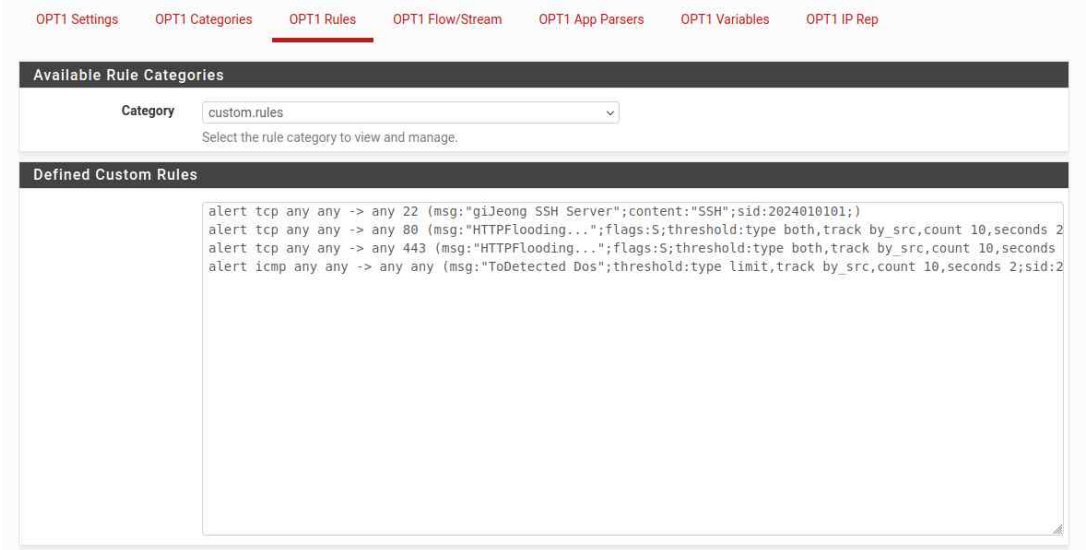

pfSense의 Package Manager에서 Suricata 패키지를 설치하였다.

### 2. 인터페이스 적용



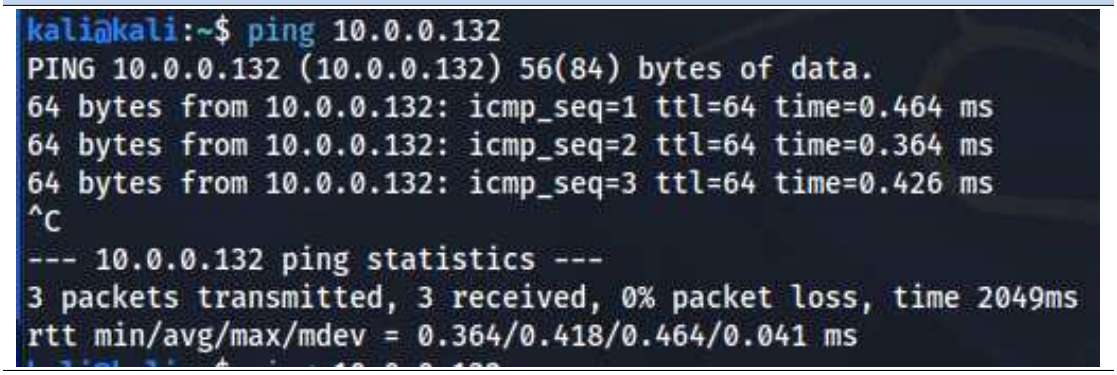

Suricata를 OPT1 인터페이스에 적용하고 활성화하였다. 해당 인터페이스를 통해 들어오는 트래픽을 실시간으로 분석하여 침입 탐지 및 차단이 가능하도록 설정하였다.

## 3-1. ICMP 룰 적용 - 허용




사용자 정의 룰(custom rules)을 설정하여 ICMP 트래픽을 탐지하도록 설정하였다.
이 단계에서는 정상적인 ping 요청이 허용되도록 구성하였다.

## 3-2. ping 확인 - 허용



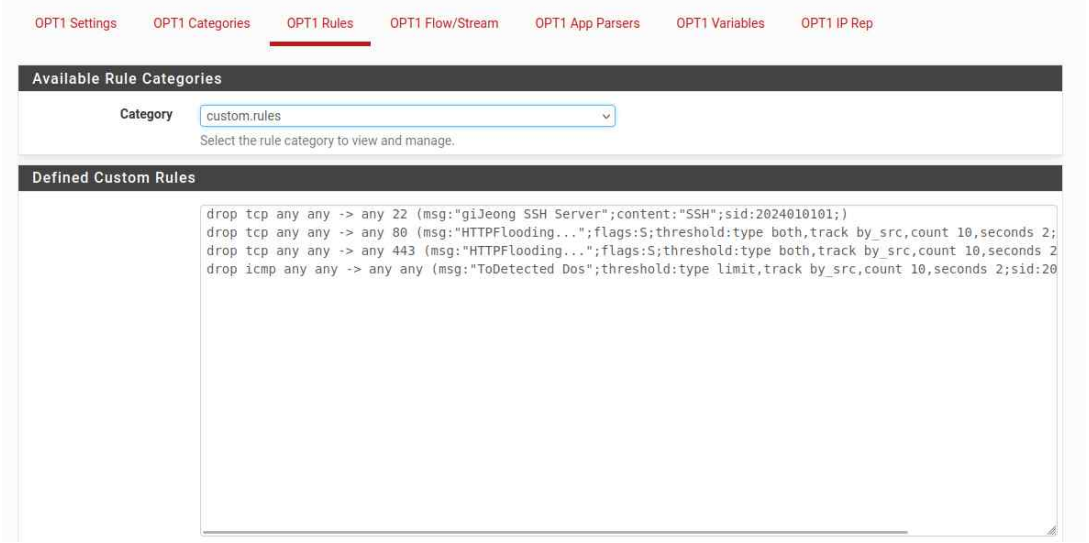

Kali에서 대상 서버(10.0.0.132)로 ping을 수행한 결과 정상적으로 응답이 확인되었다.
이는 ICMP 트래픽이 차단되지 않고 허용된 상태임을 의미한다.

## 3-3. Alert 확인 - 허용



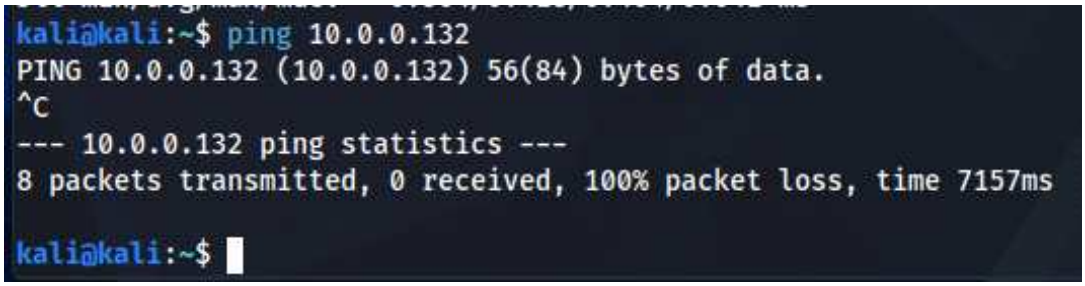

Suricata Alerts 메뉴에서 ICMP 트래픽이 탐지(alert)되는 것을 확인하였다.

## 4-1. ICMP 룰 적용 - 막음



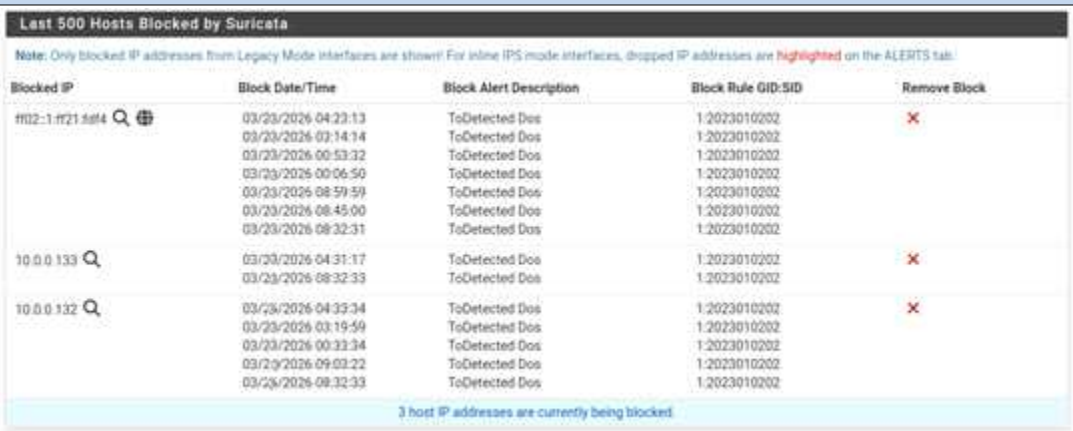

사용자 정의 룰을 alert에서 drop으로 변경하여 ICMP 트래픽을 차단하도록 설정하였다.

## 4-2. ping 확인 - 막음




Kali에서 동일한 대상 서버로 ping을 수행한 결과 응답이 없고 100% packet loss가 발생하였다. 이는 ICMP 트래픽이 차단되고 있음을 의미한다.

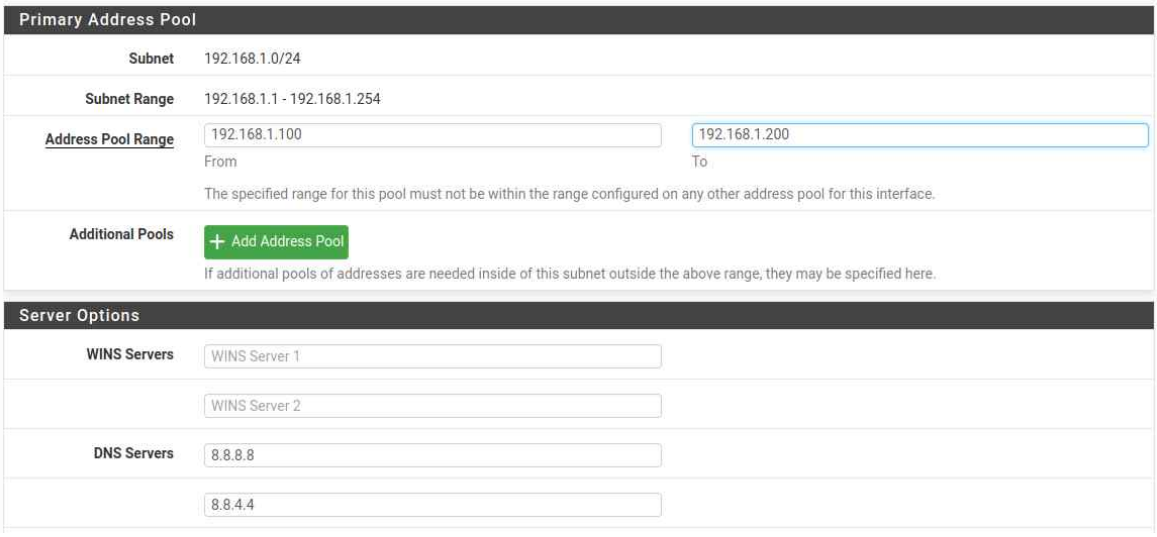
## 4-3. Block 확인 - 막음




Suricata의 Block 목록에서 공격을 수행한 IP가 차단된 것을 확인하였다.

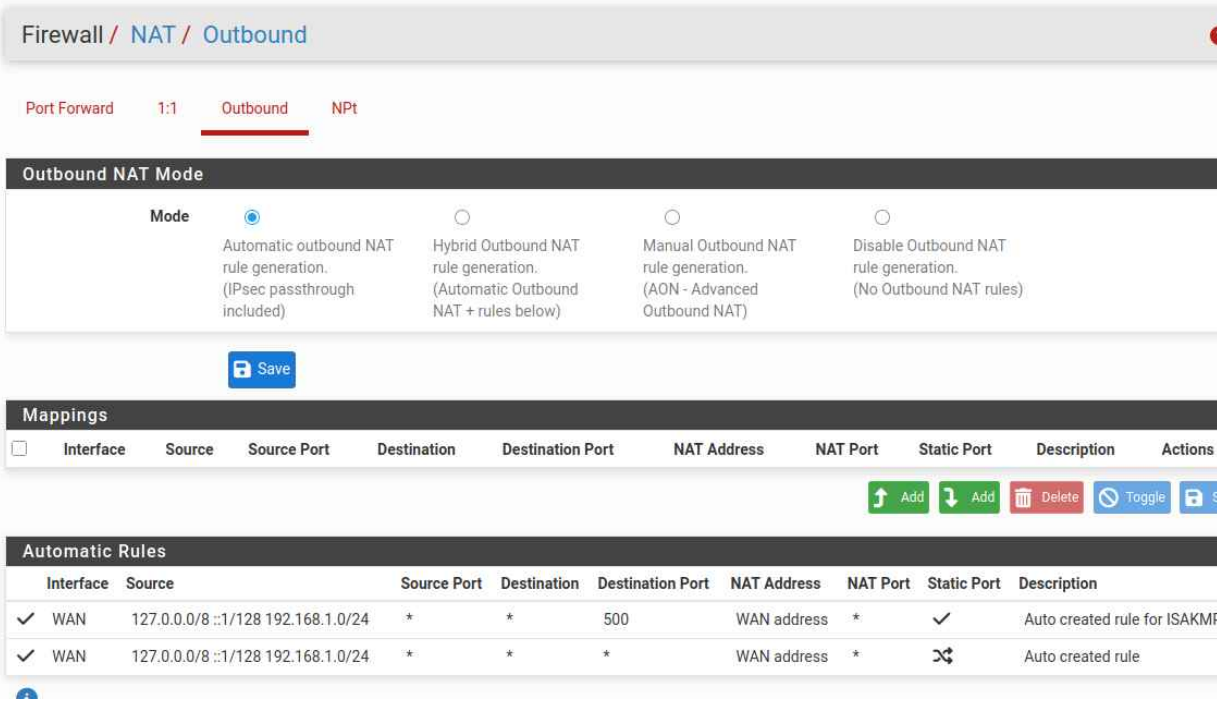
## □ DHCP서버 및 NAT/Bridge 설정

### 1. DHCP 서버 설정



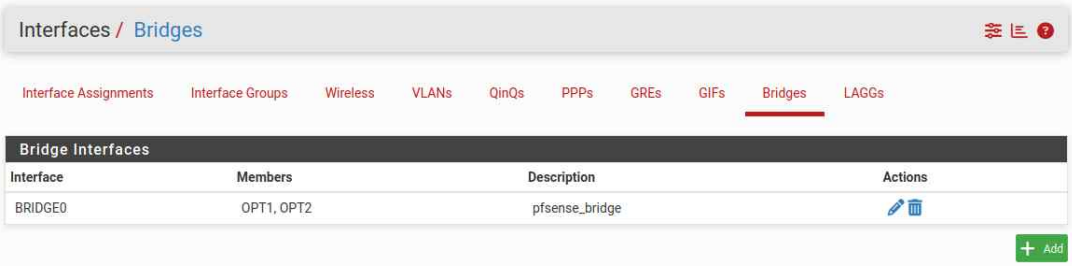

DHCP 서버를 활성화하고 내부 네트워크(192.168.1.0/24)에 대해 IP 주소 자동 할당 범위를 설정하였다. DHCP 서버를 활성화하고 Address Pool Range를 192.168.1.100 ~ 192.168.1.200으로 지정하고, DNS 서버(8.8.8.8, 8.8.4.4)를 설정하여 클라이언트가 자동으로 IP 및 DNS 정보를 할당받도록 구성하였다.

### 2. NAT 설정



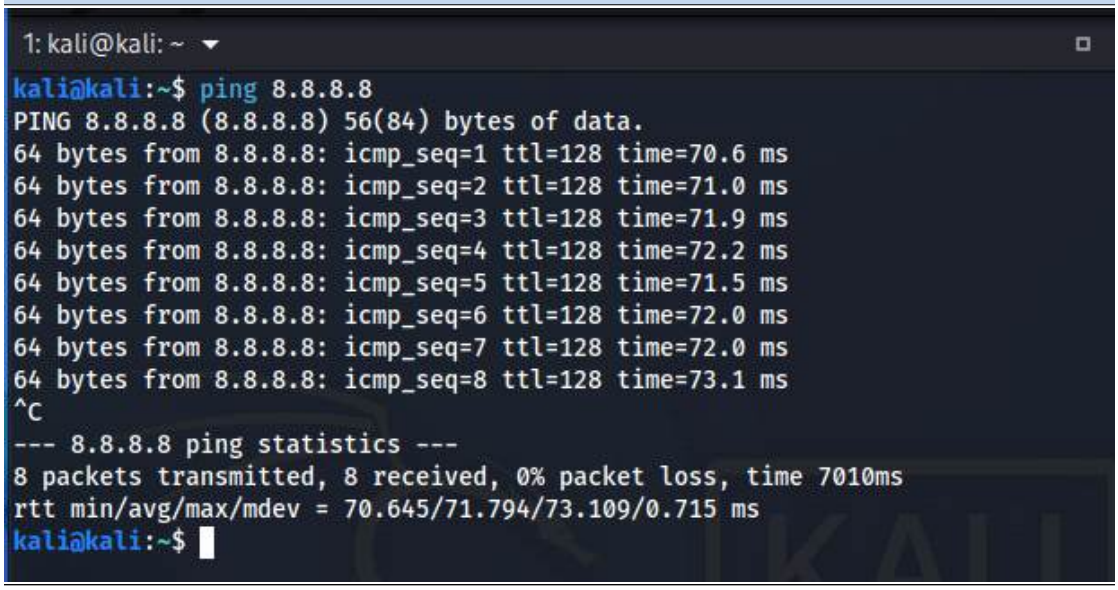

내부 네트워크에서 외부 인터넷으로 통신이 가능하도록 Outbound NAT를 Automatic 모드로 설정하여 이를 통해 내부 IP 주소를 WAN 주소로 변환하여 외부 네트워크와 통신할 수 있도록 구성하였다.

## 3. Bridge 설정




OPT1과 OPT2 인터페이스를 Bridge로 구성하여 동일한 네트워크처럼 동작하도록 설정하였다. 이를 통해 서로 다른 인터페이스 간에도 Layer 2 수준에서 통신이 가능하도록 구성하였다.

## 4. 인터넷 연결 확인




Kali Linux에서 외부 DNS 서버(8.8.8.8)로 ping 테스트를 수행한 결과 정상적으로 응답이 확인되었다. 이를 통해 NAT 설정이 정상적으로 동작하여 내부 네트워크에서 외부 인터넷 연결이 가능함을 확인하였다.

## □ 내부 네트워크 구축

### 1. 웹 서버 구동 및 방화벽 설정

```
roror@10.0.0.201's password:
Last login: Thu Mar 26 11:45:44 2026
[roror@alma ~]$ sudo -i
[sudo] password for roror:
[root@alma ~]# dnf install httpd* -y
Last metadata expiration check: 0:10:03 ago on Thu Mar 26 12:03:30 2026.
Package httpd-2.4.63-4.el10_1.3.x86_64 is already installed.
Package httpd-core-2.4.63-4.el10_1.3.x86_64 is already installed.
Package httpd-devel-2.4.63-4.el10_1.3.x86_64 is already installed.
Package httpd-filesystem-2.4.63-4.el10_1.3.noarch is already installed.
Package httpd-manual-2.4.63-4.el10_1.3.noarch is already installed.
Package httpd-tools-2.4.63-4.el10_1.3.x86_64 is already installed.
Dependencies resolved.
Nothing to do.
Complete!
[root@alma ~]# systemctl enable --now httpd
[root@alma ~]# firewall-cmd --permanent --add-service=http
Warning: ALREADY_ENABLED: http
success
[root@alma ~]# firewall-cmd --reload
success
[root@alma ~]# vi /var/www/html/index.html
```

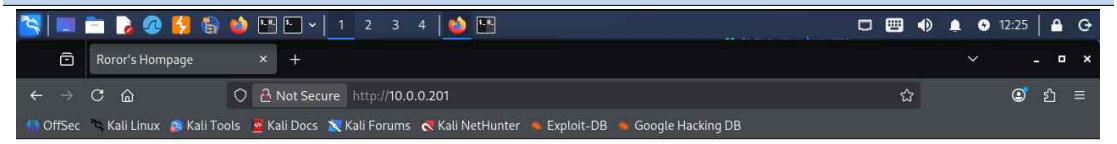
AlmaLinux 서버에 httpd 웹 서버를 설치하고 서비스를 활성화하였다. 또한, firewall-cmd를 이용하여 HTTP를 허용하여 외부에서 웹 서버에 접속할 수 있도록 방화벽 설정을 수행하였다.

### 2. 초기 웹 페이지 설정

```
1: root@alma:~
<html>
<head>
<title>Roror's Hompage</title>
</head>
<body>
<center><h2><p>Roror's Hompage</p></h2></center>
</body>
</html>
~
~
~
~
~
~
```

vi로 /var/www/html/index.html 파일을 수정하여 기본 웹 페이지를 생성하였다. 간단한 HTML 코드를 작성하여 웹 브라우저 접속 시 사용자 정의 페이지가 출력되도록 구성하였다.

## 3. 웹 서버 접속




Roror's Hompage

클라이언트(Kali Linux)에서 웹 브라우저를 이용하여 웹 서버(10.0.0.201)에 접속한 결과, 설정한 "Roror's Homepage" 페이지가 정상적으로 출력되는 것을 확인하였다.

# V. DoS(ICMP) 공격 차단 설정

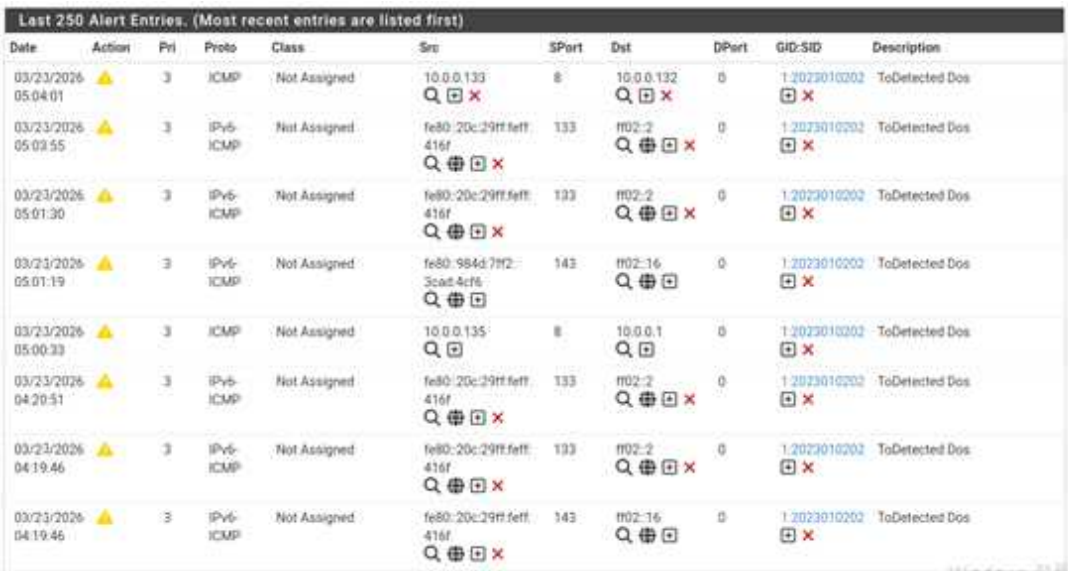
## 1. Dos 공격

```
1: root@kali: /home/kali
kali@kali:~$ sudo -s
[sudo] kali 암호:
root@kali:/home/kali# hping3 10.0.0.132 --icmp --faster -c 100
HPING 10.0.0.132 (eth0 10.0.0.132): icmp mode set, 28 headers + 0 data bytes
len=46 ip=10.0.0.132 ttl=64 id=33059 icmp_seq=0 rtt=2.9 ms
len=46 ip=10.0.0.132 ttl=64 id=33060 icmp_seq=1 rtt=2.9 ms
len=46 ip=10.0.0.132 ttl=64 id=33061 icmp_seq=2 rtt=2.8 ms
len=46 ip=10.0.0.132 ttl=64 id=33062 icmp_seq=3 rtt=2.6 ms
len=46 ip=10.0.0.132 ttl=64 id=33063 icmp_seq=4 rtt=2.5 ms
len=46 ip=10.0.0.132 ttl=64 id=33064 icmp_seq=5 rtt=2.5 ms
len=46 ip=10.0.0.132 ttl=64 id=33065 icmp_seq=6 rtt=2.3 ms

--- 10.0.0.132 hping statistic ---
100 packets transmitted, 7 packets received, 93% packet loss
round-trip min/avg/max = 2.3/2.6/2.9 ms
```

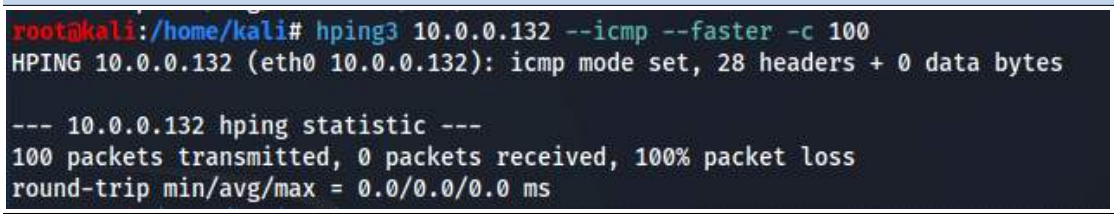
Kali Linux에서 hping3를 사용해 대상 서버(10.0.0.132)에 공격을 수행하였다. --icmp --faster -c 100 을 통하여 다량의 ICMP 패킷을 빠르게 전송해 DoS 공격을 발생시켰다.

## 2. 공격 확인




Suricata의 Alerts 로그를 확인한 결과, ICMP 기반 DoS 공격이 "ToDetected Dos" 이벤트로 탐지된 것을 확인하였다.

3. 공격 차단




동일한 ICMP 공격을 수행한 결과, 패킷 응답이 없고 100% packet loss가 발생하였다. 이는 Suricata의 IPS 기능에 의해 공격 트래픽이 차단되었음을 의미한다.